

MARK.AI

Project Security Assessment Document

1. Executive Summary

1.1 Project Overview

MARK.AI is an all-in-one AI-powered platform designed to replace the need for multiple separate tools. Instead of using different applications for lead management, email marketing, social media scheduling, and content creation, MARK.AI brings everything together in one platform.

The platform consists of 13 integrated modules.

Phase	Timeline	Scope (as provided)
1 – MVP	0–3 months	Auth, Lead Discovery, AI Research, Email Outreach, Campaign Builder, CRM, Analytics
2 – Growth	4–6 months	CRM Integration layer, WhatsApp, LinkedIn automation, Social Media automation
3 – Scale	9–14 months	AI Reply Agent, Proposal Generator, Meeting Scheduler, advanced SEO/Blog, MIS & KPI reporting
4 – Autonomous	15–24 months	Fully autonomous growth agent executing high-level commands end-to-end

MARK.AI is a multi-tenant AI platform where multiple businesses use the same system securely. It manages personal and business information of leads who may not directly register on the platform. The platform connects with various external services like email, WhatsApp, LinkedIn, social media, CRMs, and AI providers. The main security risks come from:

- Keeping different customer data separate and protected.
- Securing third-party lead information.
- Managing risks from multiple external integrations.
- Ensuring safe and controlled AI-based automation.

1.2 Top Risks (Initial View)

#	Risk	Why it matters	Risk Level
1	Multi-tenant data isolation	If proper security controls are not implemented, one company's leads, CRM information, or marketing campaigns could accidentally become visible or accessible to another company using the platform.	High
2	Lead data sourcing & consent (Lead Discovery / Enrichment)	MARK.AI collects and enhances personal information of people who may not have directly signed up or given information to the platform. This creates privacy and legal responsibilities under Indian and international data protection laws.	High

#	Risk	Why it matters	Risk Level
3	Sprawl of third-party credentials	MARK.AI connects with multiple platforms such as email, WhatsApp, LinkedIn, social media, CRMs, and AI services. Each connection requires secure access credentials. If any API key or access token is exposed, attackers could misuse it and potentially access sensitive data from multiple customers.	High
4	Autonomous agent (Phase 4) acting without adequate guardrails	AI agent can automatically plan and send communications based on user instructions. If it makes mistakes or sends inappropriate messages, it could create compliance issues or damage the company's reputation.	Medium–High

1.3 Key Recommendations

- Complete a Data Protection Impact Assessment (DPIA) before launching lead collection and enrichment features. Ensure the methods used to collect lead data are legally reviewed and approved.
- Store all third-party API keys and access tokens securely in a central secrets management system. Use separate access controls for each customer and integration, and regularly rotate credentials.
- Add human approval steps before enabling fully automated AI outreach, so important communications are reviewed before being sent.

2. Project Security Overview

2.1 Project Architecture (as described)

MARK.AI is a multi-tenant SaaS platform. A platform base (Authentication, Role-Based Access Control, multi-tenant foundation) underlies 13 modules grouped into four functional areas:

Group	Modules
Discovery & Research	1. Lead Discovery Engine · 2. Business Intelligence / Lead Enrichment Engine
Content & Outreach	3. AI Content Generation Engine · 4. Campaign Builder · 5. Outreach Automation · 6. AI Reply/Response Management Agent · 8. Social Media Automation · 9. SEO & Blog Automation Engine
CRM & Pipeline	7. CRM & Pipeline Intelligence · 13. CRM Integration & Extension Module
Reporting & Insights	10. Analytics & Insights Dashboard · 11. MIS Reporting Engine · 12. Sales & Marketing KPI Reporting Engine

2.2 Critical Assets

Asset	Why it is critical
Tenant accounts & credentials	Compromise gives an attacker full control of a business's outreach, CRM and brand voice.
Lead / prospect personal data (name, email, phone, company, social profile, enrichment notes)	Personal data of individuals who are not MARK.AI users – subject to Indian DPDP Act and possibly GDPR.
Third-party OAuth tokens & API keys (email, WhatsApp, LinkedIn, CRM, AI, social)	A single leaked token can be used to send messages, scrape data or exfiltrate CRM records as the tenant.
Outreach content & campaign logic	Intellectual property also a vector for reputational/spam abuse if manipulated.
CRM & pipeline data	Commercially sensitive sales data for each tenant.
AI prompts, model configuration & outputs	Can contain confidential tenant data sent to an external AI provider; prompt injection risk.
Analytics / MIS / KPI data	Business-sensitive performance data; aggregation across tenants must not leak cross-tenant insight.

3. Security Risk Assessment

3.1 Authentication, RBAC & Multi-Tenancy (Platform Base)

Field	Details
Plain-language explanation	Every tenant's data must be kept completely separate from every other tenant, and each user should only see what their role allows.
Business Impact	Poor tenant isolation could allow one customer to access another customer's leads, campaigns, or CRM data, causing serious privacy, trust, and contractual issues.
Risk Level	High
Recommended Mitigation	Ensure each customer can only access their own data by applying strict database rules, regularly testing for data leaks, enabling MFA for administrators, and using secure login tokens that automatically expire and refresh safely.

3.2 Lead Discovery Engine

Field	Details
Plain-language explanation	This module finds companies matching a profile – likely by querying external data providers or the public web. If it scrapes data without permission, this can break the source's terms of service and privacy law.
Technical explanation	The risk depends on how lead data is collected. Using unauthorised scraping methods can result in blocked access, legal issues, outdated data, and difficulty proving consent for data usage.
Business Impact	Legal exposure (breach of third-party terms, potential DPDP Act non-compliance), data quality/reputation risk, possible service blocking by source platforms.
Risk Level	High
Recommended Mitigation	Use approved and trusted data providers instead of scraping data. Keep records of where the data comes from, why it can be used, and ensure each source has been legally reviewed.

3.3 Business Intelligence / Lead Enrichment Engine

Field	Details
Plain-language explanation	This module automatically builds a full profile of each lead by pulling data from multiple sources. This is the point where the largest volume of personal data enters the system.
Technical explanation	Combining data from multiple sources creates a larger collection of personal information, making it a valuable target for attackers. Strong protection, limited access, and clear data deletion rules are required.
Business Impact	A breach here has the highest regulatory and reputational impact of any module, since it concerns personal data of non-users at scale.
Risk Level	High
Recommended Mitigation	Protect stored and transferred profile data using encryption, collect only the required information, define how long data is kept, and allow users to request deletion of their data.

3.4 AI Content Generation Engine

Field	Details
Plain-language explanation	This module writes outreach messages using AI. If tenant or lead data is sent to an external AI provider, that provider effectively sees the data too.
Technical explanation	Prompt injection (a lead's data or a malicious reply could manipulate the AI into unsafe output), data leaving the environment to an LLM API, and lack of output filtering for compliance (spam-trigger words, false claims) are the main risks.
Business Impact	Reputational damage from AI-generated content that is inaccurate, non-compliant, or manipulated by injected content; potential data exposure to the AI vendor.
Risk Level	Medium
Recommended Mitigation	Use trusted AI service providers, limit the personal data shared with AI systems, verify AI-generated content before sending it to leads, and maintain records of AI activities for tracking and audits.

3.5 Campaign Builder & Outreach Automation (Email, WhatsApp, LinkedIn, Social)

Field	Details
Plain-language explanation	This is the module that actually sends messages to leads across channels. Mistakes here can mean spam, banned accounts, or messages sent to the wrong tenant's list.
Technical explanation	Each customer should have separate sending accounts and limits to prevent misuse. The system should track user consent, follow platform rules, and prevent one customer's campaigns from affecting another customer.
Business Impact	Sending unwanted messages can lead to compliance issues, account suspension from platforms, and damage to sender reputation, which may impact all customers using the platform.
Risk Level	High
Recommended Mitigation	Implement consent/opt-out tracking per channel, enforce per-tenant sending limits, monitor sender reputation, isolate sending credentials per tenant.

3.6 AI Reply / Response Management Agent

Field	Details
Plain-language explanation	This AI reads incoming replies and responds automatically, and later can draft proposals and book meetings. A wrong or manipulated reply could commit the business to something incorrect.
Technical explanation	Autonomous reply generation without human review is exposed to prompt injection from the lead's own reply text, and to "hallucinated" commitments (pricing, promises) if not constrained.
Business Impact	Could send factually wrong or legally binding-sounding statements to a real prospect, requiring damage control by the business owner.
Risk Level	Medium–High
Recommended Mitigation	Constrain the agent with approved response templates/guardrails, require human approval for high-stakes replies (proposals, pricing, meeting confirmations) at least initially, log all AI-generated replies for review.

3.7 CRM & Pipeline Intelligence + CRM Integration & Extension Module

Field	Details
Plain-language explanation	This module connects to each tenant's own CRM (e.g. HubSpot, Zoho, Salesforce) and keeps data in sync both ways.
Technical explanation	Two-way sync means MARK.AI both reads and writes the tenant's CRM – an overly broad OAuth scope or a bug in sync logic could corrupt or leak CRM data. Each connector is a distinct integration to secure.
Business Impact	Corruption or leakage of a tenant's core sales data; loss of tenant trust; potential contractual liability.
Risk Level	High

3.8 Social Media Automation & SEO/Blog Automation Engine

Field	Details
Plain-language explanation	These modules post to social media and publish blog/SEO content automatically, using stored credentials/tokens for each platform.
Technical explanation	Broad publishing-scope tokens, if leaked, allow an attacker to post as the tenant's brand. Automated blog publishing also needs safeguards against AI-generated inaccurate or plagiarised content.
Business Impact	Brand/reputation damage from unauthorised or incorrect posts; SEO penalty risk from low-quality automated content.
Risk Level	Medium

3.9 Analytics, MIS & KPI Reporting Engines

Field	Details
Plain-language explanation	These modules generate business reports and summaries. If data access is not properly controlled, information from different customers could accidentally get mixed or exposed.
Technical explanation	If benchmarking uses data from multiple customers, it must be anonymised properly to avoid exposing any customer's information. Reports and exports should follow the same security rules and only include authorised data.
Business Impact	A reporting-layer leak is often overlooked but has the same impact as a direct data breach.
Risk Level	Medium

3.10 Phase 4 – Autonomous Orchestration Layer

Field	Details
Plain-language explanation	In the final phase, the AI will work as an automated growth assistant. The owner only needs to provide a business objective, and the AI will create and execute campaigns across all 13 modules with approval required for important actions.
Technical explanation	This is the highest security risk because the AI has access to all modules and can perform many actions automatically. If it is compromised or misunderstands a user's goal, it could send incorrect, excessive, or non-compliant communications on a large scale.
Business Impact	A single incorrect or manipulated AI execution could cause widespread reputational damage, legal or compliance issues, and financial losses.
Risk Level	High
Recommended Mitigation	Define hard-coded guardrails (max messages/day, banned content categories, mandatory approval thresholds) independent of the AI's own reasoning; require human approval before Phase 4 goes live for any tenant; full audit trail of every autonomous action; kill-switch to pause the agent per tenant.

3.11 Security Testing Tools and Methodologies

Security Requirement	Verification	Expected Outcome
Audit Logging	Confirm comprehensive audit logs for login, data export, privilege changes, and other high-risk events.	Complete audit trail available for monitoring and compliance.
2FA Enforcement	Verify two-factor authentication is enabled for all administrator accounts.	Administrative access protected with multi-factor authentication.
Encryption Verification	Confirm encryption is enabled both in transit (TLS 1.2+) and at rest (AES-256).	Sensitive data remains protected during transmission and storage.
API Rate Limiting	Test rate-limiting for integrated services such as WhatsApp and LinkedIn APIs.	Prevents abuse, denial-of-service attacks, and third-party account bans.

4. Security Across the Project Lifecycle

4.1 During Development

Risk	Preventive Control	Verification Method
Secrets (API keys/tokens) committed to code repository	Use environment variables/secrets manager; pre-commit secret scanning	Automated secret-scan in CI on every commit
Vulnerable open-source dependencies	Dependency allow-listing; lock files; update policy	Automated dependency/SCA scan in CI
Insecure code patterns (injection, broken auth, insecure deserialisation)	Secure coding guidelines; peer code review	SAST (Static Application Security Testing) scan on each pull request
Tenant isolation not enforced consistently across modules	Shared authorization middleware used by all 13 modules; no module bypasses it	Automated cross-tenant access test suite
Test/staging environments using real tenant or lead data	Synthetic/masked test data only	Data classification review before each release

4.2 Pre-Launch

Risk	Preventive Control	Verification Method
Undiscovered vulnerabilities in exposed APIs/webhooks	External penetration test scoped to APIs and webhooks	Independent pen-test report with remediation sign-off
Missing incident response plan	Draft IR plan incl. CERT-In 6-hour reporting workflow	
Third-party integrations not reviewed for least-privilege scopes	Review OAuth scopes for every connected service	Manual scope audit checklist
No data retention/erasure policy published	Define and publish retention schedule and deletion process for lead data	Legal/compliance sign-off
Load/availability risk for outreach sending infrastructure	Load testing of Outreach Automation and Campaign Builder	Performance test report

4.3 Post-Launch

Risk	Preventive Control	Verification Method
Credential/token compromise over time	Scheduled key/token rotation; anomaly alerts on API usage	Quarterly access/credential review
New vulnerabilities in dependencies post-release	Continuous dependency scanning and patch cadence	Monthly vulnerability scan report
Gradual scope creep as new modules (Phase 2–4) are added	Re-run isolation and OAuth-scope review for every new module/integration	Security review gate at each phase release
Undetected data exfiltration or misuse by the autonomous agent (Phase 4)	Continuous monitoring/SIEM alerting on agent actions; anomaly thresholds	Monthly SIEM review + audit log sampling
Incident not reported within statutory window	Documented, rehearsed CERT-In / DPDP breach-notification runbook	Annual incident-response drill

5. Third-Party Integration Security

Every external integration is a shared-responsibility relationship: MARK.AI is responsible for how it stores, scopes and uses the credentials and data it receives; the vendor is responsible for the security of its own platform.

5.1 Email Provider (ESP / SMTP)

Field	Details
Purpose	Send outreach email campaigns (MVP) and receive reply data.
Data Exchanged	Lead email addresses, message content, open/click tracking, reply content.
Authentication Method	API key or OAuth (provider-dependent) – Information Required: exact provider not named.
Security Risks	Sender domain/IP reputation shared across tenants if not isolated; API key leakage allows spam-sending as the tenant; email content may contain PII.
Vendor Dependency Risk	Deliverability depends entirely on the ESP's reputation systems and policy changes.
Shared Responsibility	MARK.AI: key storage, per-tenant sending isolation. Vendor: platform uptime, anti-abuse detection.
Recommended Controls	Per-tenant sending domain/subdomain (DKIM/SPF/DMARC), key rotation, bounce/complaint monitoring, encrypted storage of reply content.

5.2 WhatsApp Business API

Field	Details
Purpose	Outreach and two-way conversation with leads on WhatsApp (Growth phase).
Data Exchanged	Phone numbers, message content, opt-in/opt-out status, media attachments.
Authentication Method	Typically OAuth/token-based via WhatsApp Business Platform (Meta) or a BSP (Business Solution Provider) – Information Required: direct Meta integration vs. BSP.
Security Risks	Strict opt-in messaging rules – violations can get the tenant's WhatsApp number banned; message templates must be pre-approved; phone numbers are personal data.
Vendor Dependency Risk	Meta/BSP policy changes can suspend messaging capability platform-wide with little notice.
Shared Responsibility	MARK.AI: consent capture and storage, template compliance. Vendor: message delivery, spam enforcement.
Recommended Controls	Store explicit opt-in evidence per lead; use only approved templates; monitor quality rating per tenant number; token rotation and per-tenant number isolation.

5.3 LinkedIn API / Automation

Field	Details
Purpose	Find and enrich leads, send connection/outreach messages, automate social posting.
Data Exchanged	Professional profile data, connection activity, message content.
Authentication Method	OAuth (official API) or session-based automation (if using browser automation) – Information Required: which method is used.
Security Risks	LinkedIn's terms restrict automation and scraping; violation risk is account suspension for the tenant, and possible legal exposure for MARK.AI as the automation provider.
Vendor Dependency Risk	High – LinkedIn actively detects and blocks automation; a platform-side policy change can disable a whole module.

Field	Details
Shared Responsibility	MARK.AI: staying within LinkedIn's official API terms. Vendor: enforcement of its own anti-automation policy.
Recommended Controls	Prefer official LinkedIn Marketing/Sales Navigator APIs over unofficial automation; rate-limit per tenant; clear tenant disclosure of LinkedIn ToS risk.

5.4 Other Social Media APIs (e.g. Facebook/Instagram, X/Twitter)

Field	Details
Purpose	Automated posting and engagement for Social Media Automation module.
Data Exchanged	Post content, page/account access tokens, engagement metrics.
Authentication Method	OAuth 2.0, platform-issued access/refresh tokens.
Security Risks	Broad-scope tokens could allow account takeover-level actions (posting, deleting, messaging) if leaked.
Vendor Dependency Risk	Each platform's API policy and rate limits differ and change independently.
Shared Responsibility	MARK.AI: token scoping and storage. Vendor: platform security and takedown of abusive apps.
Recommended Controls	Request minimum publishing-only scopes; per-tenant token isolation; token expiry monitoring and re-consent flow.

5.5 CRM Integrations (Module 13 – e.g. HubSpot, Zoho, Salesforce)

Field	Details
Purpose	Two-way sync of leads, contacts, deals and pipeline stages with the tenant's own CRM.
Data Exchanged	Full contact and deal records, potentially including notes and historical communication.
Authentication Method	OAuth 2.0 per CRM platform – Information Required: confirmed CRM(s) to be supported at launch.
Security Risks	Overly broad OAuth scopes; sync bugs causing data corruption or duplication; one compromised CRM connector could expose the tenant's entire sales history.
Vendor Dependency Risk	Each CRM vendor's API rate limits and deprecation cycles can break sync unexpectedly.
Shared Responsibility	MARK.AI: scope minimisation, sync integrity. Vendor: CRM platform security, uptime.
Recommended Controls	Minimum-necessary OAuth scopes; write-operation logging with rollback capability; per-tenant, per-CRM credential isolation; sync error alerting.

5.6 AI / LLM API Provider(s)

Field	Details
Purpose	Powers AI Content Generation, Enrichment summarisation, and the AI Reply Agent.
Data Exchanged	Prompts that may include lead PII, tenant business content, and CRM context; generated outputs.
Authentication Method	API key – Information Required: confirmed vendor(s) and data-processing terms.
Security Risks	Data leaving MARK.AI's environment to a third-party model; prompt injection from lead-supplied text; potential model training on submitted data if not contractually excluded.
Vendor Dependency Risk	Pricing, rate limits and model behaviour are controlled entirely by the vendor; model updates can change output behaviour without notice.

Field	Details
Shared Responsibility	MARK.AI: what data is included in prompts, output validation. Vendor: model security, data handling per its DPA.
Recommended Controls	Choose a vendor offering a Data Processing Agreement with a no-training-on-customer-data commitment; minimise PII in prompts; log prompts/outputs for audit; sanitise lead-supplied text before it reaches the model.

5.7 Lead Data Sources (Lead Discovery Engine)

Field	Details
Purpose	Supplies the raw company/contact matches for the Lead Discovery Engine.
Data Exchanged	Company and contact details of individuals who are not MARK.AI users.
Authentication Method	Information Required – confirmed data source(s) (licensed data API vs. web/scraping) not specified.
Security Risks	Legality of source (ToS violation, DPDP/GDPR lawful-basis question), data accuracy/freshness, potential blocking by source platforms.
Vendor Dependency Risk	A single data-source vendor becoming unavailable or non-compliant could halt the core discovery function.
Shared Responsibility	MARK.AI: lawful basis and documentation for each source. Vendor: data accuracy and its own compliance.
Recommended Controls	Prefer licensed data providers with clear terms permitting resale/use; maintain a documented data-source registry reviewed by legal counsel.

5.8 Webhooks (Inbound from Email, WhatsApp, LinkedIn, Social, CRM)

Field	Details
Purpose	Receive real-time events (replies, delivery status, engagement) from every connected channel.
Data Exchanged	Message content, delivery/engagement metadata, sender identifiers.
Authentication Method	Shared secret / signature verification (platform-dependent).
Security Risks	Unverified webhook endpoints can be spoofed to inject fake events or data; publicly reachable endpoints are a common attack entry point.
Vendor Dependency Risk	Each platform's webhook signature scheme differs and must be implemented correctly per integration.
Shared Responsibility	MARK.AI: signature verification and endpoint hardening. Vendor: signing key management.
Recommended Controls	Verify signatures on every webhook; use per-tenant, per-channel webhook URLs/secrets; rate-limit and log all inbound webhook calls.

6. Third-Party Security Solutions

Where a mature, purpose-built product exists, buying is generally faster and more reliable than building in-house – especially for a team focused on shipping 13 product modules across 24 months.

Category	Why Needed	Build vs Buy	Suitable Vendors/Tools (examples)	Integration Complexity	Typical Licensing Model
Authentication / Identity (IAM)	Multi-tenant login, MFA, SSO for enterprise clients	Buy	Auth0, AWS Cognito, Okta, Microsoft Entra ID	Low–Medium	Per active user / per monthly active user
Web Application Firewall (WAF)	Blocks common web attacks (SQLi, XSS) at the edge before they reach the app	Buy	Cloudflare, AWS WAF, Azure Front Door WAF	Low	Per request volume / flat monthly
API Security / Gateway	13 modules expose many APIs – needs centralised auth, rate limiting, schema validation	Buy (with in-house policy config)	Kong, AWS API Gateway, Wallarm, Salt Security	Medium	Per API call volume or contact sales
Secrets Management	Central, rotated storage for the large number of third-party tokens described in Section 5	Buy	HashiCorp Vault, AWS Secrets Manager, Azure Key Vault	Low–Medium	Per secret / per workload
Vulnerability Scanning	Finds known weaknesses in infrastructure and containers	Buy	Qualys, Tenable Nessus, AWS Inspector	Low	Per asset / per workload
SAST (Static Code Analysis)	Catches insecure code before merge, across a fast-moving multi-module codebase	Buy	Semgrep, SonarQube, GitHub CodeQL, Checkmarx	Low–Medium	Per developer / contact sales
Dependency (SCA) Scanning	Flags vulnerable open-source packages used across modules	Buy	Snyk, GitHub Dependabot, OWASP Dependency-Check (free)	Low	Per project / free tier available
SIEM / Log Correlation	Correlates events across 13 modules and many third-party webhooks to detect incidents	Buy	Microsoft Sentinel, Splunk, Wazuh (open-source)	Medium–High	Per data volume ingested
Application/Infra Monitoring (APM)	Availability and performance visibility, early warning of abuse (e.g. sending spikes)	Buy	Datadog, New Relic, Grafana + Prometheus (open-source)	Low–Medium	Per host / per metric volume
Cloud Security Posture Mgmt (CSPM)	Continuously checks cloud configuration for misconfigurations across environments	Buy	Wiz, Prisma Cloud, Microsoft Defender for Cloud	Medium	Per cloud workload

7. Compliance & Regulatory Considerations

Only frameworks relevant to MARK.AI's described design are covered below.

7.1 Applicable Indian Laws

Law / Direction	Why it matters here
Digital Personal Data Protection Act, 2023 (DPDP Act)	MARK.AI processes personal data of leads (name, email, phone, enrichment data) as a Data Fiduciary; requires lawful basis/consent, purpose limitation, data-subject rights (e.g. erasure), and breach notification to the Data Protection Board.
Information Technology Act, 2000 (incl. Sections 43A & 72A)	Governs liability for failure to protect “sensitive personal data” and unauthorised disclosure of information by an intermediary/service provider such as MARK.AI.
CERT-In Directions (April 2022)	Mandates reporting of specified cyber incidents to CERT-In within 6 hours, maintaining logs of ICT systems for 180 days within India, and designating a Point of Contact.
RBI Guidelines (payment-related)	Not applicable based on the modules described – no payment/financial transaction module is present. Information Required: confirm if a payment gateway is added in a later phase.

7.2 International Considerations

Regulation	Why it matters here
GDPR (EU)	Applies if MARK.AI or its tenants target or process personal data of individuals in the EU/EEA – relevant since Lead Discovery/Enrichment may surface leads globally. Information Required: confirm target markets.
CAN-SPAM / similar email regulations (e.g. US, Canada CASL)	Applies to Email Outreach Automation if leads in those jurisdictions are contacted – requires opt-out mechanism, sender identification.
HIPAA	Not applicable – no health data is described in the current modules.
PCI DSS	Not applicable – no payment card processing is described in the current modules.

7.3 Recognised Security Frameworks

Framework	Relevance to MARK.AI
OWASP Top 10	Baseline web application risks (injection, broken access control, etc.) – directly relevant to the tenant portal and all module UIs.
OWASP API Security Top 10	Highly relevant – MARK.AI is API-heavy (13 modules, many webhooks and third-party integrations).
OWASP ASVS	Useful as a verification checklist during development and for the external agency's architecture review (Section 8).
NIST Cybersecurity Framework	Useful high-level structure (Identify, Protect, Detect, Respond, Recover) for the overall security programme, especially as the platform scales toward Phase 4 autonomy.
ISO/IEC 27001	Worth targeting as the platform matures and sells to enterprise tenants who will ask for it in vendor due-diligence.
CIS Controls	Practical, prioritised baseline for DevOps/infrastructure hardening.